ONE-PAGE BRIEF

Post-quantum cryptography review: trezor-vendored-crypto @ 72489948b3c4

Client: Trezor (vendored primitives) — public repository (passive review) · Source: github.com/trezor/trezor-firmware, commit `72489948b3c4` · Reviewed: 2026-11-04 19:36 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
Level 1 of 4
post-quantum code present, not wired

FINDINGS
0 Critical **0** High **4** Medium
0 Low **0** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Key establishment: 10 + 5 − 8 = 7 → **too late**
Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Wire the existing post-quantum primitive into a critical path (key wrapping or the channel) behind a hybrid construction, and test interoperability.

WHAT MATTERS MOST

Medium QSI-2026-12889	**Quantum-vulnerable ECDSA: transaction and message signing (21 file(s))** confirmed by the analyst What to do: Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum signature schemes as chains…
Medium QSI-2026-12891	**Quantum-vulnerable Schnorr (BIP-340): transaction and message signing (3 file(s))** confirmed by the analyst What to do: Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum signature schemes as chains…
Medium QSI-2026-12888	**Quantum-vulnerable Ed25519: role not determined (5 file(s))** confirmed by the analyst What to do: Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/composite form…
Medium QSI-2026-12890	**Quantum-vulnerable ECDH: role not determined (4 file(s))** confirmed by the analyst What to do: Classify each usage, record data lifetimes, and plan migration to Hybrid key establishment with ML-KEM (FIPS 203), e.g. X25519MLKEM768 in…

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium transaction and message signing	ECDSA, Schnorr (BIP-340)	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum…
Medium role not determined	Ed25519, ECDH	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)…

Analyst review: 4 confirmed, 0 not applicable, 0 dismissed as false positives. (QSI review, 2026-10-29)

Static review of source code and manifests; files analysed: 510. No requests were sent to the owner's systems.

Full report, content SHA-256: `487f14cbb0c7e7be4ab1ac3ef88d38f863fafb73da4da9bc920f75bebb1087fd`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.